

OWASP Zed Attack Proxy Heads-Up Display (ZAP HUD) Setup and Usage Guide

1. Download and install Java SDK 8 (a prerequisite for OWASP ZAP) for your operating system from the Java project page (<https://www.java.com/en/download/manual.jsp>)

The screenshot shows the 'Java Downloads for All Operating Systems' page. It includes a sidebar with 'Help Resources' (Troubleshoot Java, Where can I get Java?, Looking for the JDK?), a 'Recommended Version 8 Update 301' section with a license update warning, and a table of download links for Windows, Mac OS X, and Linux. The Windows section lists 'Windows Online' (2 MB), 'Windows Offline' (70.72 MB), and 'Windows Offline (64-bit)' (81.08 MB). The Mac OS X section lists 'Mac OS X (10.7.3 version and above)' (83.05 MB). The Linux section lists 'Linux RPM' (58.85 MB), 'Linux' (87.97 MB), and 'Linux x64' (88.16 MB). Each entry has a link to 'Instructions'.

Java Downloads for All Operating Systems

Recommended Version 8 Update 301
Release date July 20, 2021

Important Oracle Java License Update

The Oracle Java License has changed for releases starting April 16, 2019. The new Oracle Technology Network License Agreement for Oracle Java SE is substantially different from prior Oracle Java licenses. The new license permits certain uses, such as personal use and development use, at no cost -- but other uses authorized under prior Oracle Java licenses may no longer be available. Please review the terms carefully before downloading and using this product. An FAQ is available [here](#).

Commercial license and support is available with a low cost [Java SE Subscription](#).

Oracle also provides the latest OpenJDK release under the open source [GPL License](#) at [jdk.java.net](#).

Select the file according to your operating system from the list below to get the latest Java for your computer.

[All Java Downloads](#) [Remove Older Versions](#) [What is Java?](#)

By downloading Java you acknowledge that you have read and accepted the terms of the [Oracle Technology Network License Agreement for Oracle Java SE](#)

Windows Which should I choose?

Download Link	File Size	Instructions	Notes
Windows Online	2 MB	Instructions	After installing Java, you may need to restart your browser in order to enable Java in your browser.
Windows Offline	70.72 MB	Instructions	
Windows Offline (64-bit)	81.08 MB	Instructions	

If you use 32-bit and 64-bit browsers interchangeably, you will need to install both 32-bit and 64-bit Java in order to have the Java plug-in for both browsers. » [FAQ about 64-bit Java for Windows](#)

Mac OS X Mac FAQ

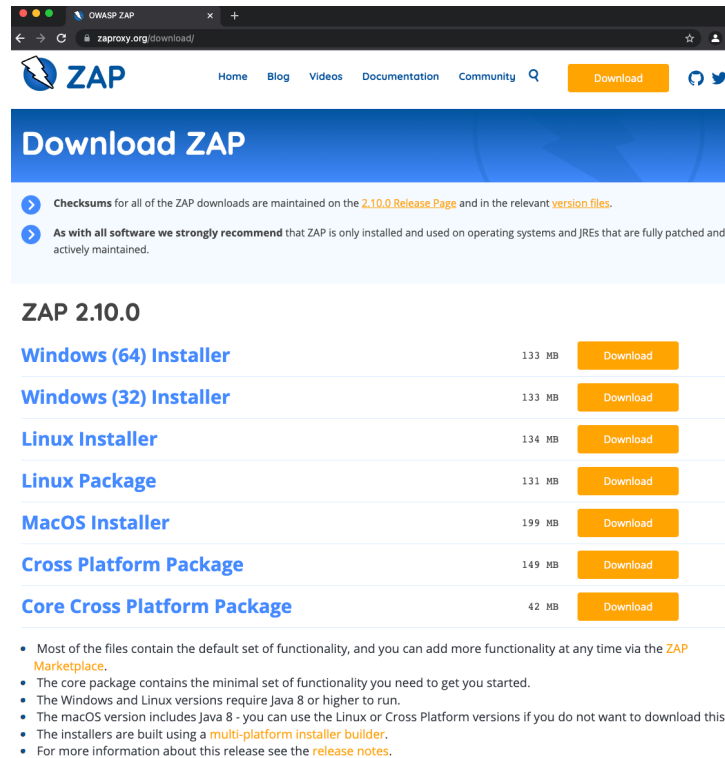
Download Link	File Size	Instructions	Notes
Mac OS X (10.7.3 version and above)	83.05 MB	Instructions	After installing Java, you may need to restart your browser in order to enable Java in your browser.

* Oracle Java (Version 7 and later versions) requires an Intel-based Mac running Mac OS X 10.7.3 (Lion) or later and administrator privileges for installation. » [More information](#)

Linux

Download Link	File Size	Instructions	Notes
Linux RPM	58.85 MB	Instructions	After installing Java, you will need to enable Java in your browser.
Linux	87.97 MB	Instructions	
Linux x64	88.16 MB	Instructions	

2. Download and install the OWASP ZAP project (<https://www.zaproxy.org/download/>) through the various ways listed below (pick one)
 - a. Install ZAP through a pre-packaged installer for your operating system



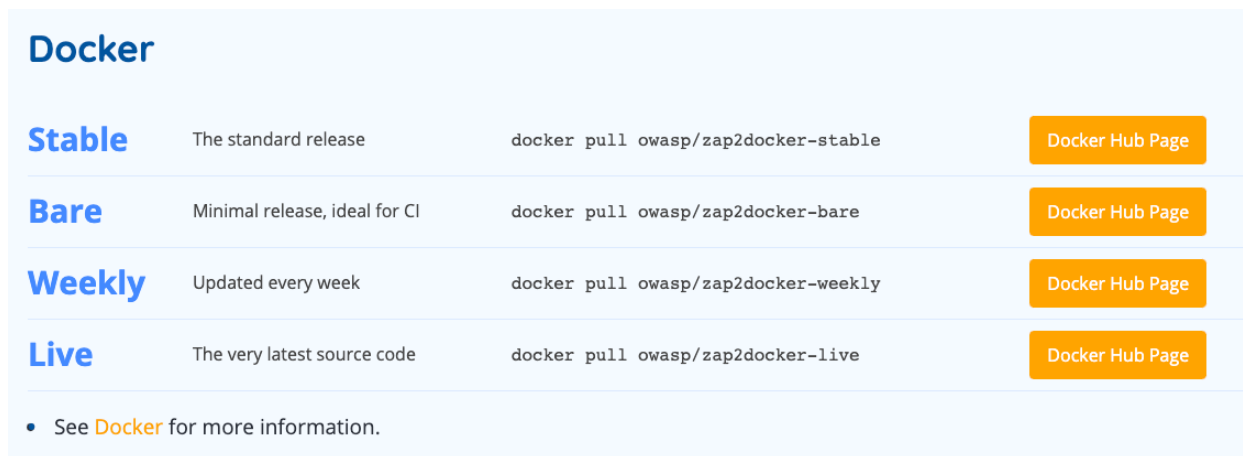
The screenshot shows the OWASP ZAP download page. At the top, there's a navigation bar with links to Home, Blog, Videos, Documentation, and Community, along with a search icon and a 'Download' button. Below the navigation bar is a large blue banner with the text 'Download ZAP'. Underneath the banner, there are two informational boxes: one about checksums and another recommending that ZAP be installed on fully patched and actively maintained operating systems and JREs. The main section is titled 'ZAP 2.10.0' and lists various download options with their respective sizes and 'Download' buttons:

Download Option	Size	Action
Windows (64) Installer	133 MB	Download
Windows (32) Installer	133 MB	Download
Linux Installer	134 MB	Download
Linux Package	131 MB	Download
MacOS Installer	199 MB	Download
Cross Platform Package	149 MB	Download
Core Cross Platform Package	42 MB	Download

Below the table, there are several bullet points providing additional information:

- Most of the files contain the default set of functionality, and you can add more functionality at any time via the [ZAP Marketplace](#).
- The core package contains the minimal set of functionality you need to get you started.
- The Windows and Linux versions require Java 8 or higher to run.
- The macOS version includes Java 8 - you can use the Linux or Cross Platform versions if you do not want to download this.
- The installers are built using a [multi-platform installer builder](#).
- For more information about this release see the [release notes](#).

- b. Deploy a Docker Instance



The screenshot shows the Docker deployment options for OWASP ZAP. It features a table with four rows, each representing a different release type: Stable, Bare, Weekly, and Live. Each row includes a description, the Docker pull command, and a 'Docker Hub Page' button.

Release Type	Description	Docker Pull Command	Action
Stable	The standard release	<code>docker pull owasp/zap2docker-stable</code>	Docker Hub Page
Bare	Minimal release, ideal for CI	<code>docker pull owasp/zap2docker-bare</code>	Docker Hub Page
Weekly	Updated every week	<code>docker pull owasp/zap2docker-weekly</code>	Docker Hub Page
Live	The very latest source code	<code>docker pull owasp/zap2docker-live</code>	Docker Hub Page

Below the table, there is a bullet point:

- See [Docker](#) for more information.

- c. Download from a repository using your OS package manager through the command line
 - i. For Linux: Official repositories and instructions can be found here (<https://software.opensuse.org/download.html?project=home%3Acabelo&package=owasp-zap>)

owasp-zap from **home:cabelo** project

Select Your Operating System



CentOS



Debian



Fedora



Mageia



openSUSE



RHEL



SL



SLE



Ubuntu



Univention

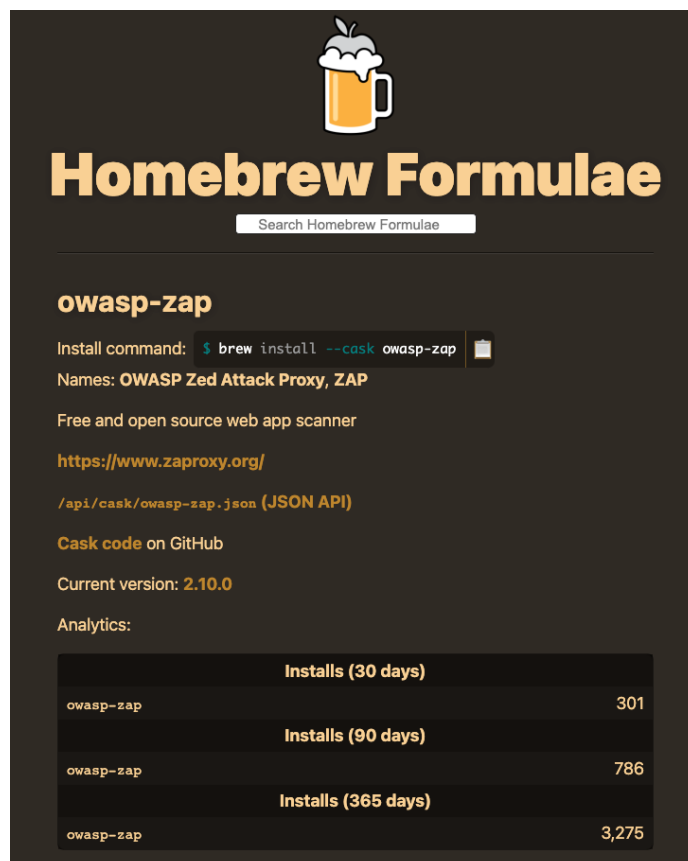


Unknown

Add repository and install manually

Grab binary packages directly

- ii. For MacOS: Install via homebrew (<https://formulae.brew.sh/cask/owasp-zap#default>)



The image shows the Homebrew Formulae page for the **owasp-zap** formula. At the top is the Homebrew logo (a beer mug with a unicorn) and the title "Homebrew Formulae". Below the title is a search bar labeled "Search Homebrew Formulae". The formula name **owasp-zap** is prominently displayed. Below it, the install command is shown: `$ brew install --cask owasp-zap`. The names "OWASP Zed Attack Proxy, ZAP" are listed. A description states it is a "Free and open source web app scanner" with a link to <https://www.zaproxy.org/>. It also provides a link to the JSON API: `/api/cask/owasp-zap.json`, a link to the Cask code on GitHub, and the current version: **2.10.0**. Under the "Analytics" section, there are three tables showing install counts for different periods.

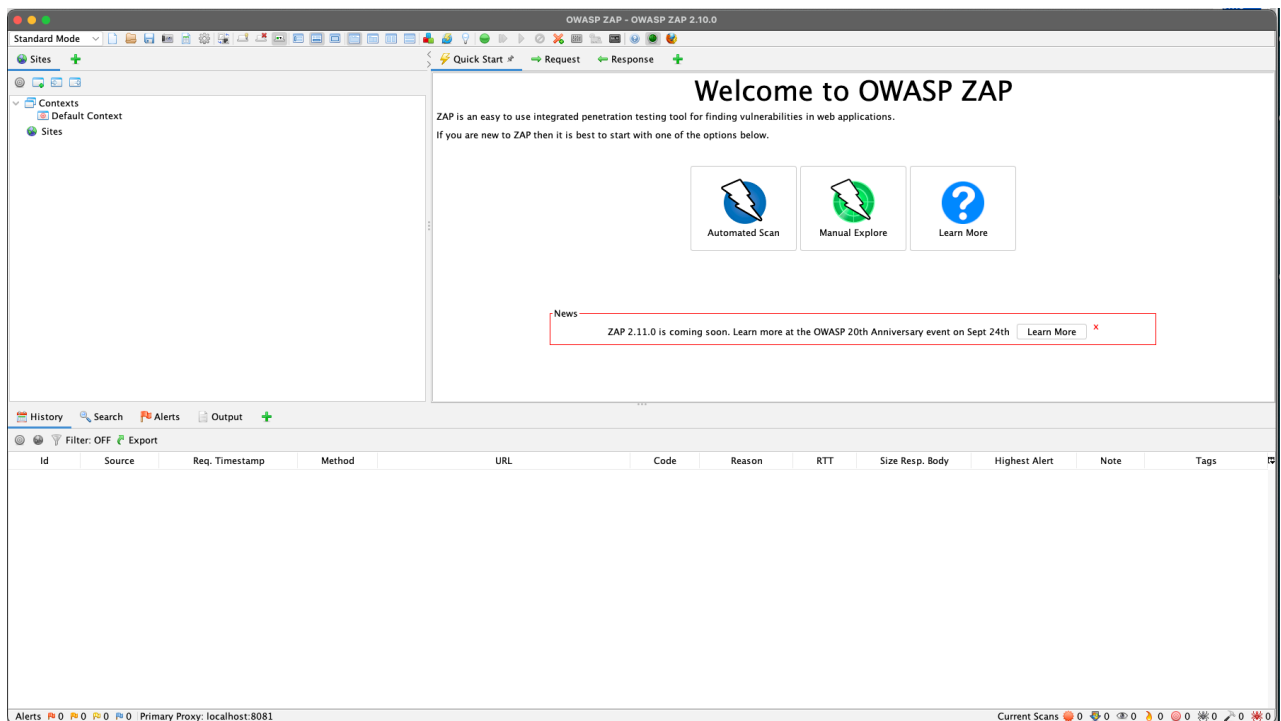
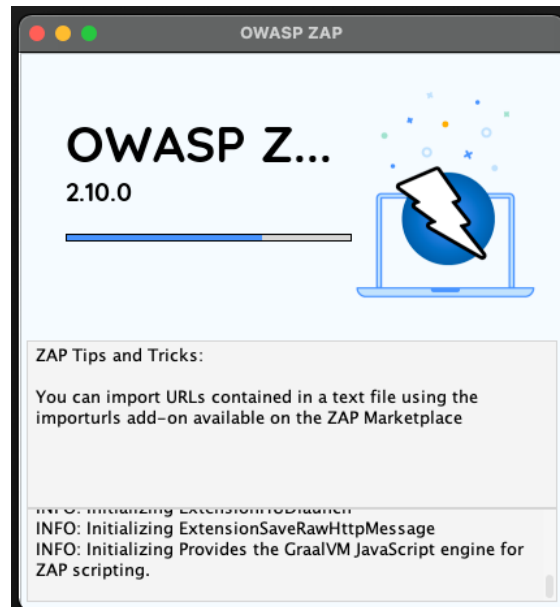
Installs (30 days)	
owasp-zap	301

Installs (90 days)	
owasp-zap	786

Installs (365 days)	
owasp-zap	3,275

```
> brew install --cask owasp-zap
Updating Homebrew...
```

3. Launch OWASP ZAP and click on **Manual Explore** on the Dashboard



4. In the Manual Explore Window, input the URL of the application to be scanned (in this example, <https://demo.testfire.net>) and make sure that the checkbox for Enable HUD is ticked; click on Launch Browser



Manual Explore



This screen allows you to launch the browser of your choice so that you can explore your application while proxying through ZAP.

The ZAP Heads Up Display (HUD) brings all of the essential ZAP functionality into your browser.

URL to explore:

Select...

Enable HUD:

☒

Explore your application:

Launch Browser

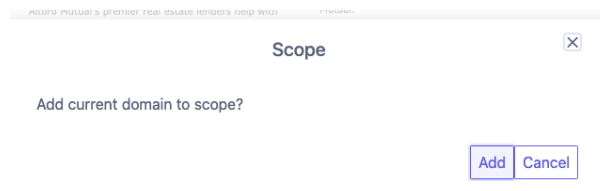
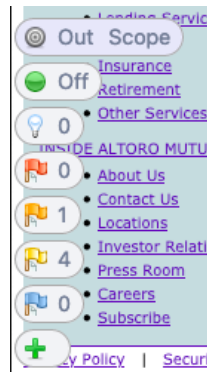
Firefox

You can also use browsers that you don't launch from ZAP, but will need to configure them to proxy through ZAP and to import the ZAP root CA certificate.

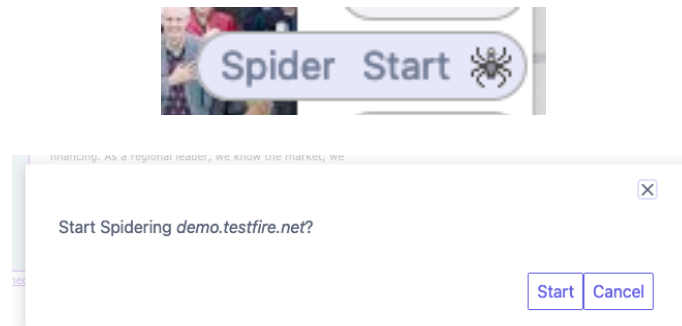
5. A separate browser window will be launched with the specified URL open and with ZAP HUD posted as an overlay to the site:



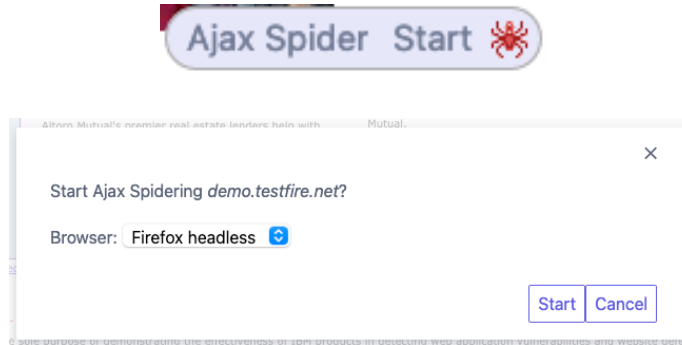
6. Take the HUD Tutorial to know more about how ZAP and HUD works; for the purpose of this guide, we'll just move on and continue to the target application (click on **Continue to your target**)
7. To make sure that ZAP only sends requests to the target application, add the current domain to the in-scope targets:
 - On the left-hand side of the screen, click on the very first element on the HUD (the icon that reads **Out**)
 - When asked if you want to add the current domain to the scope, click on **Add**
 - The icon should change to red and should now read **In**



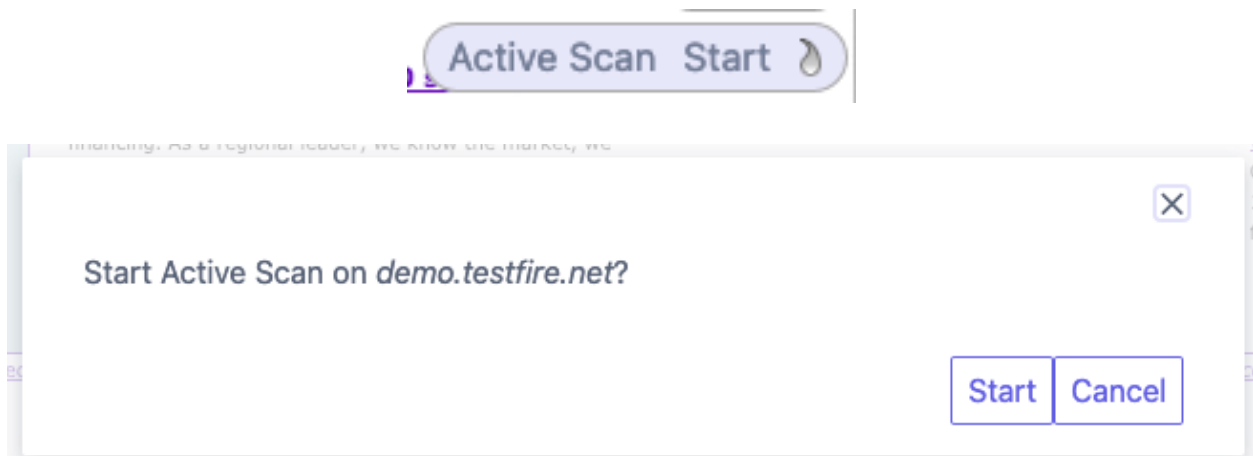
8. Start mapping the application and its directories using the Spidering Tools available; for typical Web applications, use the **Spider** tool:



For AJAX-heavy applications, use the **AJAX Spider** tool instead:



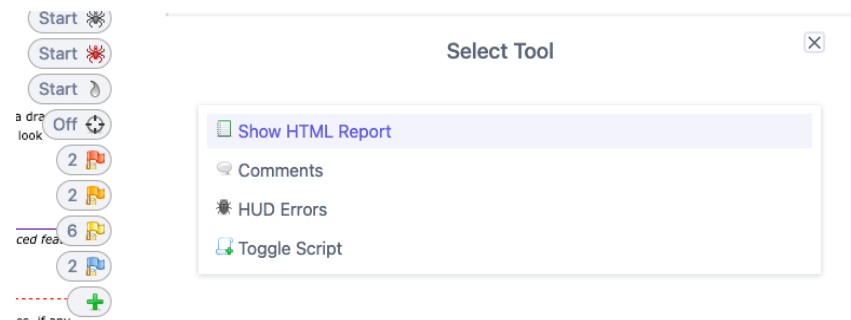
9. Navigate through the application and its various locations to add them to the Site Tree for later use in Active Scan
10. Once mapping is done, click on Active Scan and start it; this will run the scan policy checks against locations found in the Site Tree that are in the defined scope



11. Vulnerability notifications should pop-up on the right side of the screen as ZAP finds them



12. Once scanning is complete, click on the + icon on either side of the HUD overlay and select **Show HTML Report**



13. Click on the newly created icon in the overlay which should take you to an automatically generated report with the vulnerability findings of ZAP HUD

A screenshot of the ZAP Scanning Report generated on Fri, 24 Sep 2021 04:45:25. The report is displayed in a browser window with a dark theme. It includes a "Summary of Alerts" table, an "Alerts" table, and an "Alert Detail" section for "Cross Site Scripting (DOM Based)".

Summary of Alerts

Risk Level	Number of Alerts
High	2
Medium	2
Low	10
Informational	4

Alerts

Name	Risk Level	Number of Instances
Cross Site Scripting (DOM Based)	High	58
Cross Site Scripting (Reflected)	High	2
Secure Pages Include Mixed Content (Including Scripts)	Medium	1
X-Frame-Options Header Not Set	Medium	62
Absence of Anti-CSRF Tokens	Low	139
Cookie without SameSite Attribute	Low	2
Cross-Domain JavaScript Source File Inclusion	Low	1
Incomplete or No Cache-control Header Set	Low	86
Secure Pages Include Mixed Content	Low	2
X-Content-Type-Options Header Missing	Low	104
Information Disclosure - Suspicious Comments	Informational	15
Timestamp Disclosure - Unix	Informational	221

Alert Detail

High (Medium)	Cross Site Scripting (DOM Based)
	Cross-site Scripting (XSS) is an attack technique that involves echoing attacker-supplied code into a user's browser instance. A browser instance can be a standard web browser client, or a browser object embedded in a software product such as the browser within WinAmp, an RSS reader, or an email client. The code itself is usually written in HTML/JavaScript, but may also extend to VBScript, ActiveX, Java, Flash, or any other browser-supported technology. When an attacker gets a user's browser to execute his/her code, the code will run within the security context (or zone) of the hosting web site. With this level of privilege, the code has the ability to read, modify and transmit any sensitive data accessible by the browser. A Cross-site Scripted user could have his/her account hijacked (cookie theft), their browser redirected to another location, or possibly shown fraudulent content delivered by the web site they are visiting. Cross-site Scripting attacks essentially compromise the trust relationship between a user and the web site. Applications utilizing browser object instances which load content from the file system may execute code under the local machine zone allowing for system compromise. There are three types of Cross-site Scripting attacks: non-persistent, persistent and DOM-based. Non-persistent attacks and DOM-based attacks require a user to either visit a specially crafted link laced with malicious code, or visit a malicious web page containing a web form, which when posted to the vulnerable site, will mount the attack. Using a malicious form will oftentimes take place when the vulnerable resource only accepts

References:

OWASP ZAP Documentation: <https://www.zaproxy.org/docs/desktop/start/>

ZAP Spider: <https://www.zaproxy.org/docs/desktop/start/features/spider/>

ZAP AJAX Spider: <https://www.zaproxy.org/docs/desktop/addons/ajax-spider/>

ZAP Active Scan: <https://www.zaproxy.org/docs/desktop/start/features/scan/>